POPIA by design

Health information is special personal information under the Protection of Personal Information Act 4 of 2013. This document maps MediChain to the Act's eight conditions for lawful processing, shows how an access decision is made, and lists the threats it is built to resist.

The eight conditions, condition by condition

POPIA condition	How MediChain meets it
1. Accountability	Every read and change is attributed to an authenticated account; the audit stream is signed and kept write-once.
2. Processing limitation	Consent is recorded as given or refused with its legal basis; staff open a record only through a grant, a care relationship or a logged emergency.
3. Purpose specification	Each access carries a reason (treatment, emergency, and so on) that the patient can read.
4. Further processing limitation	No analytics, advertising or model training on patient data. Clinical scores are explicit rules run for that patient's care.
5. Information quality	Patients can see their own record. An unmeasured value is shown as unknown, never as zero, and forms send only what was entered.
6. Openness	Access history and consent records are visible to the patient in the app.
7. Security safeguards	Encryption in transit and at rest, step-up authentication, rate limits, alarms, backups with restore tests (below).
8. Data subject participation	Patients approve and withdraw access, sign or refuse consent, and read their notes, results, prescriptions and messages.

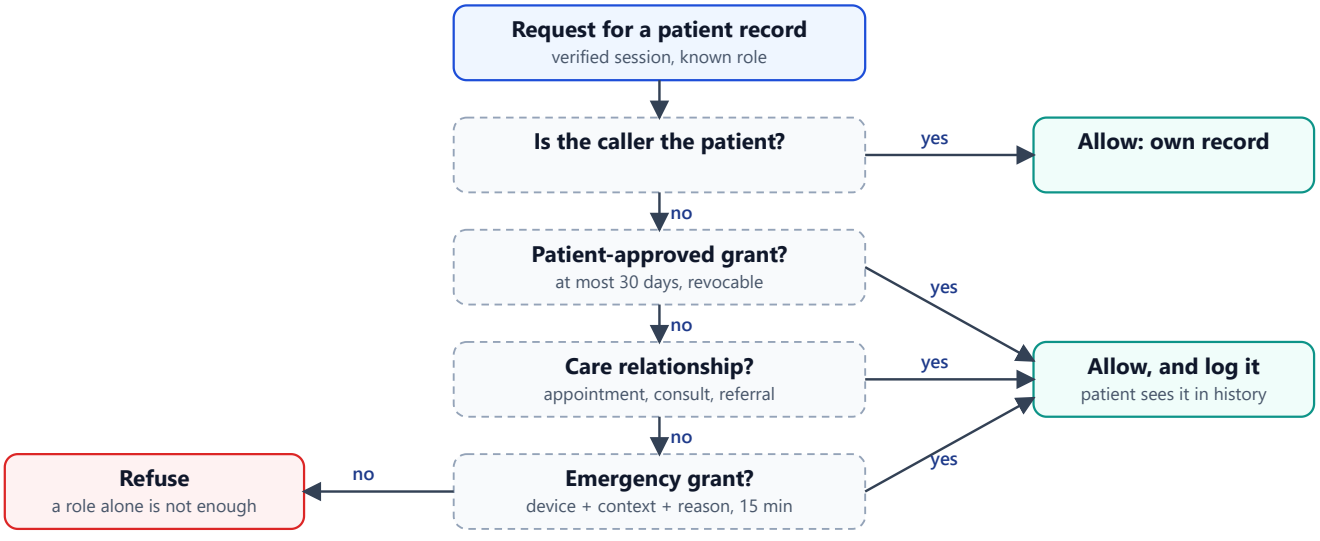


Figure 6. How the server decides whether to open a record. Administrators manage accounts and devices, never clinical records.

Threats and controls

Threat	Control
Stolen password database	The password never leaves the browser: it is stretched with PBKDF2-SHA512 (210,000 rounds) and HKDF into a proof, and the server stores Argon2id over the proof.
Password guessing	60 requests per minute for anonymous callers; account lockout after repeated failures; a CloudWatch alarm on sign-in failures and locks.
Weak or breached passwords	15 characters minimum; checked against breach lists by k-anonymity, so the password itself is never sent.
Curious staff member	A role alone opens nothing. The care relationship or grant is checked on every request, and the patient sees each read.
Misused emergency access	Only on an enrolled device, inside a work context and with a reason; it lasts 15 minutes for one patient and is flagged in the patient's history.
Forged emergency QR	The QR carries a server-signed (HMAC) proof; a typed patient number alone cannot open emergency access.
Insider rewriting the log	Each batch is fingerprinted and Ed25519-signed, then exported to S3 Object Lock, which even the account owner cannot overwrite.
Replayed or doubled writes	Every authenticated change carries an idempotency key; a replay returns the first result and changes nothing.
Cross-site attacks	A strict content security policy, HSTS, own-origin CORS, and no third-party scripts.
Privileged misuse	An authenticator-app (TOTP) step-up for role changes, guardianship and other privileged actions; administrators cannot read clinical records.
Data loss	Nightly encrypted backups to a second store, continuous WAL archiving, and an automatic restore test.

What is stored where

Data	Where	Protection
Clinical records, documents	PostgreSQL in Cape Town	Documents encrypted with ChaCha20-Poly1305; encrypted disk
Emergency summary	Encrypted emergency capsule	Only a commitment (a hash) and a version number enter the audit stream
Audit checkpoints	S3 Object Lock	Ids, digests and timestamps only, never health data
Secrets	AWS Secrets Manager	Never in source code or images

Honest status

Fictional data only until three gates close: a registered Information Officer, POPIA prior authorisation (section 57), and a health-privacy lawyer's sign-off. Records are retired, never destroyed, until retention rules are approved.